AUDITRA

Evidence-first brand governance

Every claim traced to evidence. Every approval bound to a version.

TechCircuit Round 3 — Final submission

Team Quoding

Arya Kashyap (Team Leader) · Ronit Mongia · Moli Verma

Screenshots are from the running application with the fictional Northstar Cloud demo workspace.

1 · EXECUTIVE SUMMARY

From rule checker to governance system

Marketing teams publish faster than legal and brand teams can review. AUDITRA checks copy **and image creatives** against a brand's rules and its **approved source documents** before anything ships. Each finding points to the passage, image region, rule or source behind it. Approval is enforced on the server by configurable policies and bound to an exact version, and only that version can be published.

Round 3 delivered the three committed improvements as working, tested vertical slices, plus three signature features:

- **Multimodal governance:** content-validated PNG/JPEG upload, on-server OCR with text boxes, the same rules on OCR text, WCAG contrast, palette Delta-E and logo similarity, all drawn on the creative.
- **Evidence-grounded claims:** TXT/Markdown/PDF sources split into stored passages, BM25 retrieval, and five conservative verdicts — supported, contradicted, stale, needs review, no evidence found.
- **Enterprise governance:** real accounts and sessions, per-workspace roles checked on every endpoint, approval policies, self-approval blocking, version-bound approvals and a guarded, idempotent publishing sandbox.
- **Brand DNA, Campaign consistency graph, Decision replay** — built on the same stored records, with no invented scores.

Verification: 63 passed, 0 failed (pytest, 29 Oct 2026); frontend production build succeeds. Evaluation on fictional, team-authored data: creatives 8/8 expected labels found with 0 false positives; claims 19/21 correctly classified with **0** claims wrongly marked supported. These are not real-world accuracy figures.

2 · PROBLEM AND VALUE

Why governance needs evidence, not just rules

A rule checker can say a word is banned. It cannot say whether "$59 per month" matches the current price sheet, whether the banner's disclaimer is legible, or whether the version being published is the one legal approved. Those are the failures that cause real incidents: outdated prices, unsupported claims, and last-minute edits slipping past sign-off.

Risk	How AUDITRA addresses it
Unsupported or outdated claims	Each claim is retrieved against approved sources; stale and contradicted claims trigger policies.
Text inside images escapes review	OCR feeds image text through the same rules and claim checks, with regions on the image.
Inconsistent campaign facts	Prices, dates and disclosures are compared across every asset and the brief.
Approval bypass	Server-side roles and policies; approvals bound to a version; edits invalidate approval.
Publishing the wrong version	Publish re-checks status, version and policies; refusals and duplicates are logged.

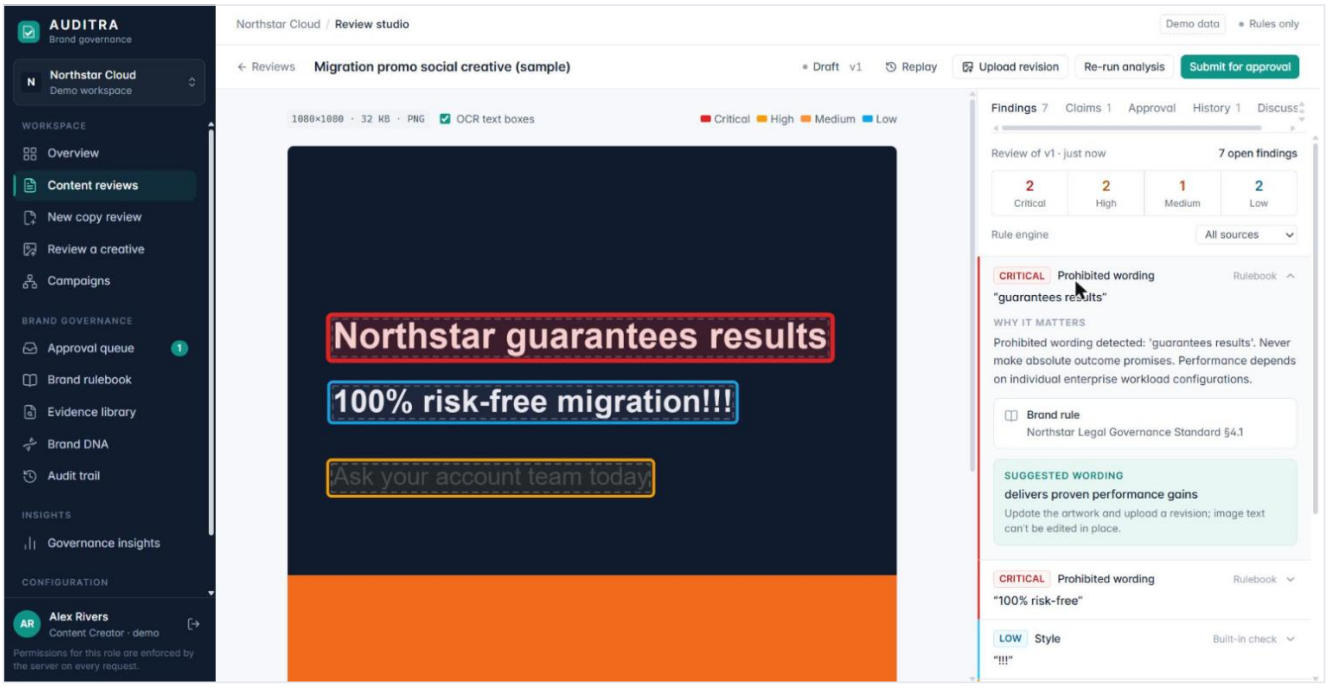
3 · IMPLEMENTED FEATURES

What works today

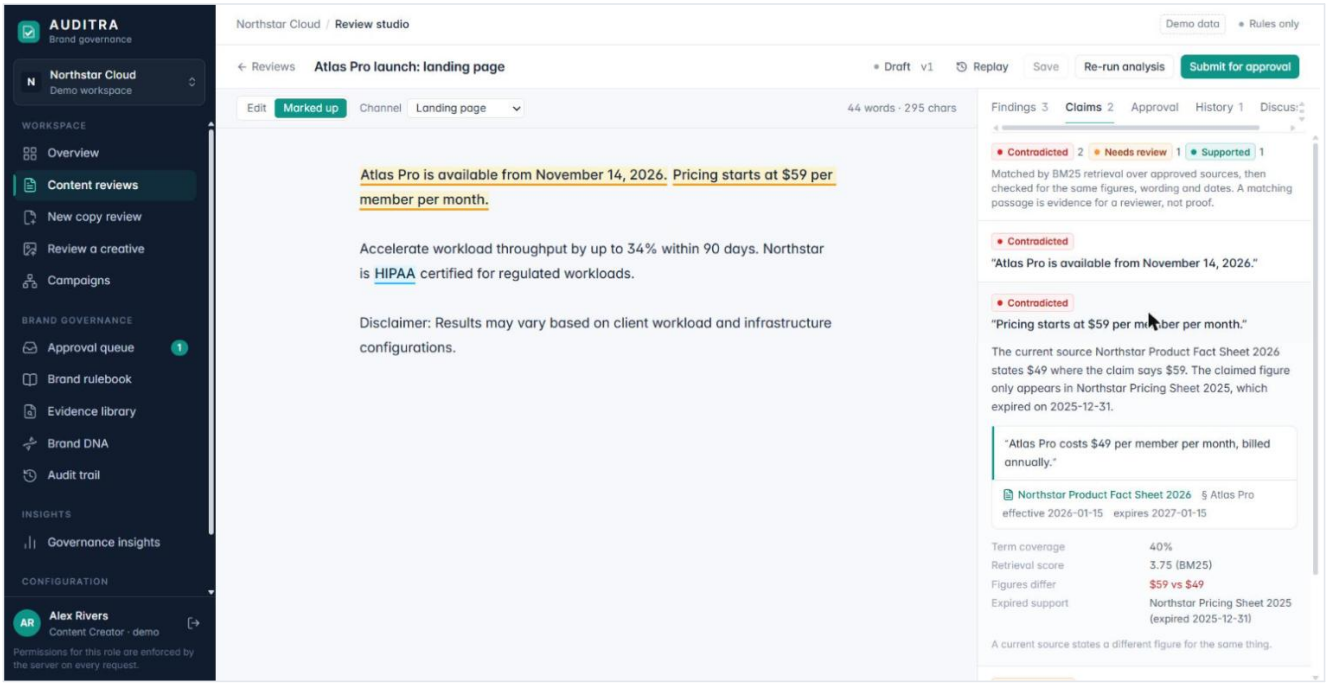
Feature	Status
Round 2: workspaces, rulebook, claims registry, rule engine, optional AI step, corrections, versions, workflow, audit, dashboard	Implemented (kept)
Authentication: email/password (PBKDF2), demo personas, HttpOnly session cookies, logout revocation	Implemented
Authorisation: creator / reviewer / admin per workspace, enforced on every endpoint	Implemented
Approval policies, version-bound approvals, self-approval block, evidence confirmation	Implemented
Publishing: local sandbox connector with export record, idempotent per version	Implemented (sandbox, not a live channel)
Creative analysis: OCR, rules on OCR text, contrast, palette, logo similarity	Implemented
Evidence library and claim verification (TXT, MD, text PDF)	Implemented
Brand DNA, contradictions, rule-change simulation	Implemented
Campaign consistency graph	Implemented
Decision replay with rule snapshots and counterfactual	Implemented (snapshots from Round 3 onward)
SSO, live CMS/social connectors, scanned-PDF OCR, video	Planned — not implemented

4 · SCREENS

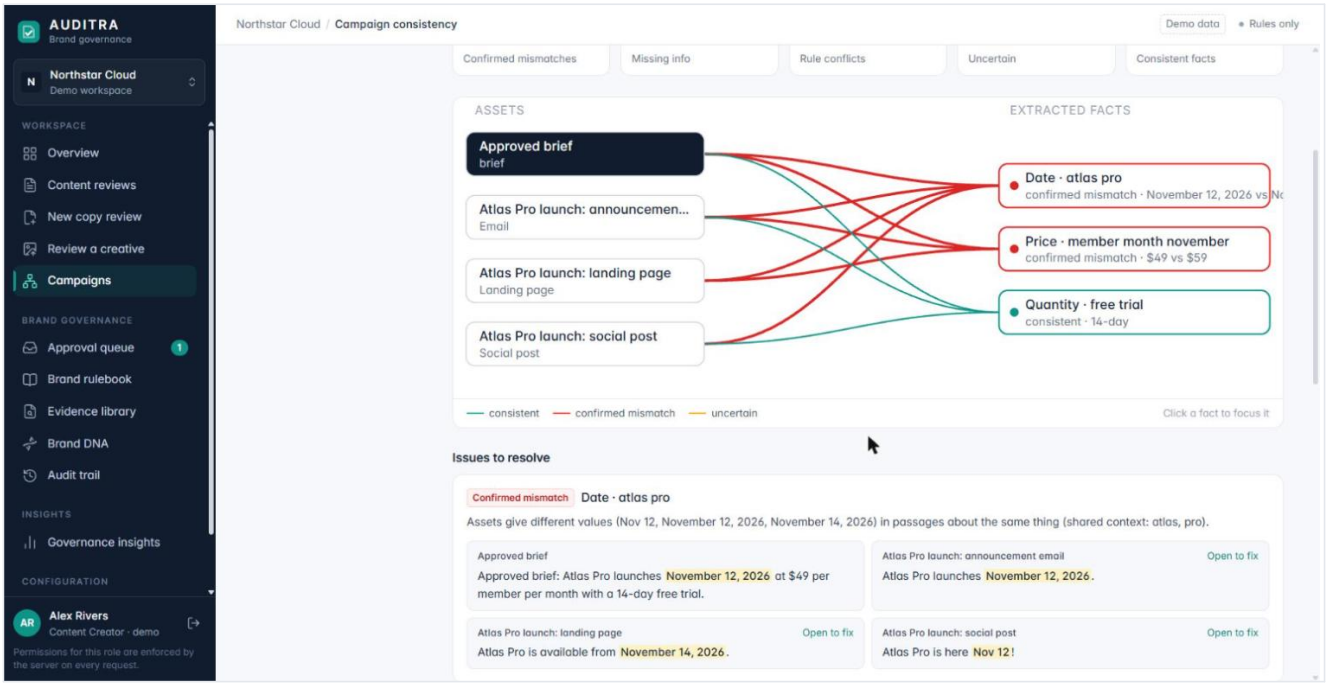
The running application



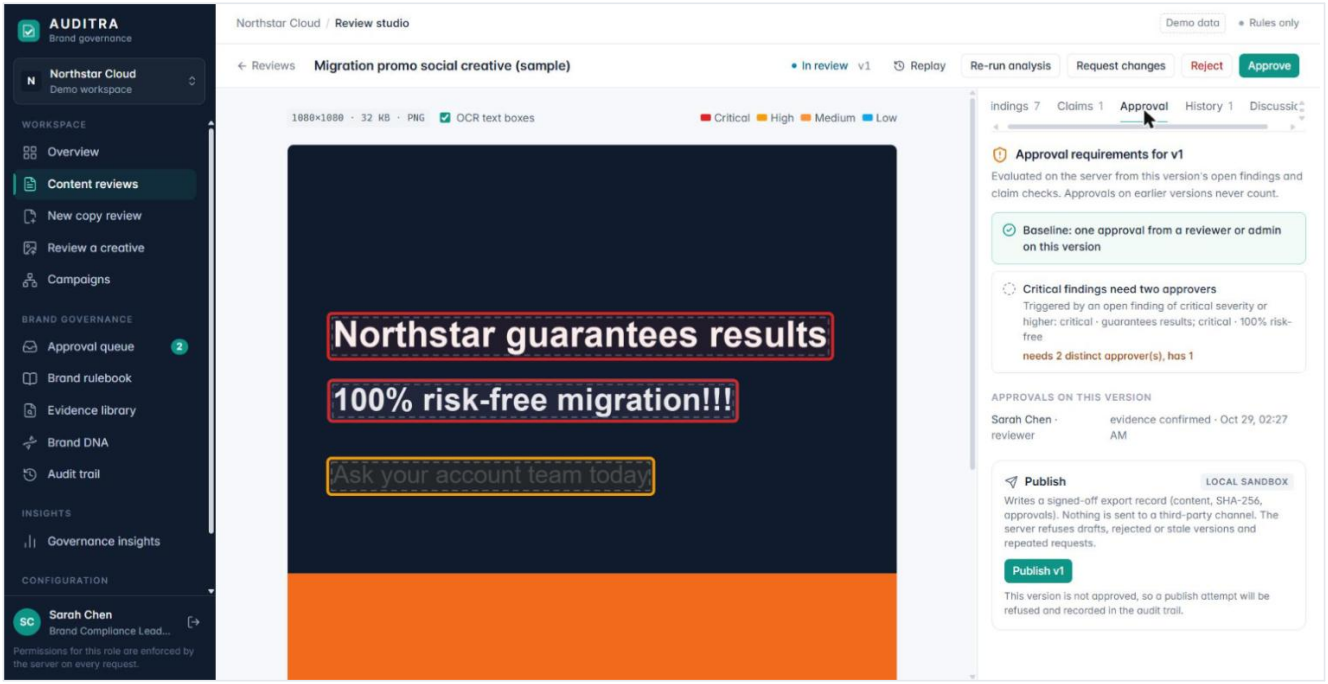
Creative review: OCR text boxes (dashed), findings drawn as severity-coloured regions, and the rule behind a finding.



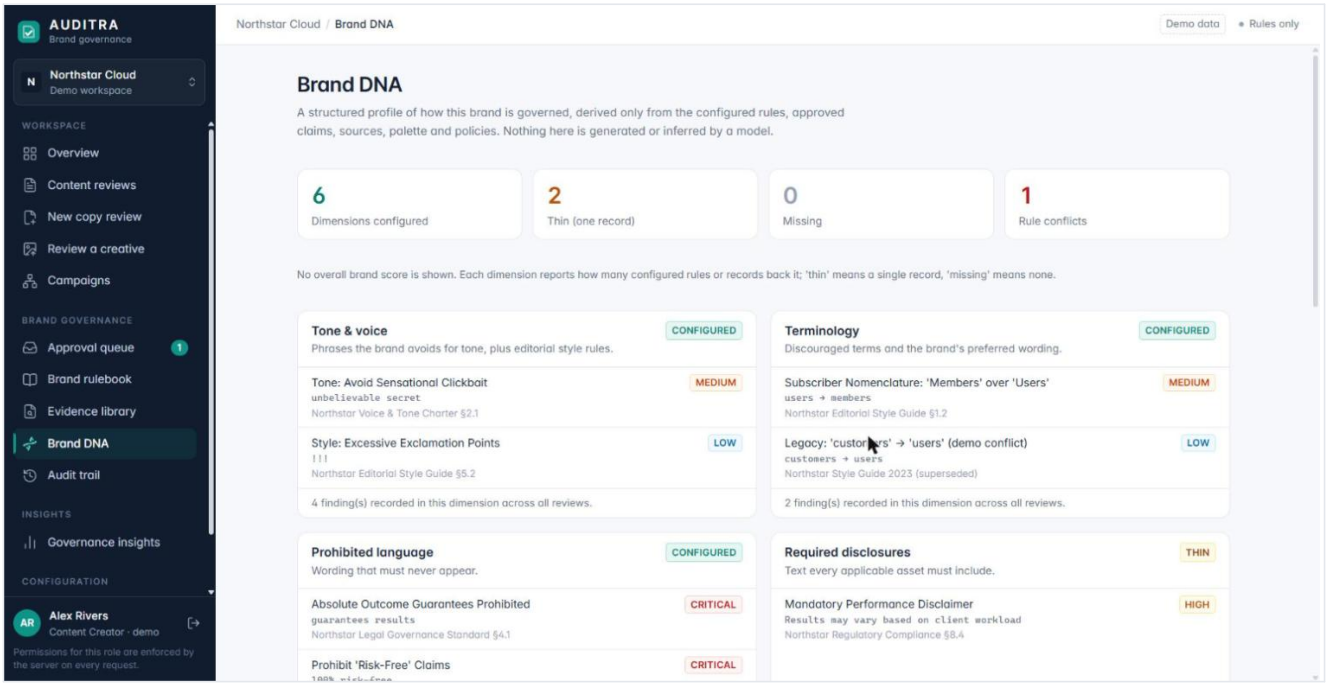
Claim evidence: "$59 per member per month" is contradicted by the current fact sheet; the cited passage, section and dates are shown.



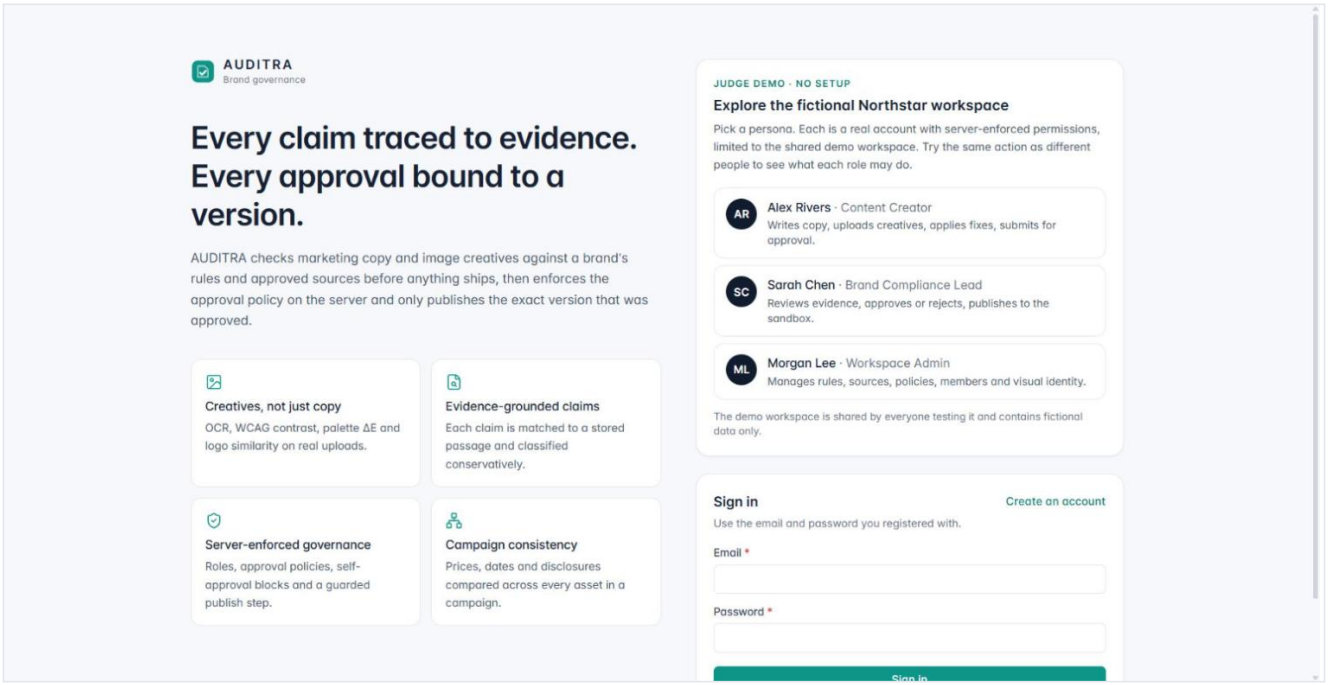
Campaign consistency: assets on the left, extracted facts on the right; the landing page disagrees on price and date, with passages side by side.



Approval requirements: a critical finding triggers the two-approver policy; one approval is recorded, publishing would be refused.



Brand DNA: dimensions derived from configured rules, with the seeded rule conflict surfaced.



Sign-in: one-click demo personas for judges, plus real registration.

5 · ARCHITECTURE

One FastAPI service, one analysis pipeline

A React + TypeScript SPA talks to a FastAPI service over JSON. Every analysis runs through `review_pipeline.py`:

- Rule engine on the current version (exact offsets).
- For creatives: findings mapped back to OCR text boxes; contrast, palette and logo measured from pixels.
- Candidate claims retrieved against approved passages and classified; contradicted and stale claims become findings.
- Findings, claim checks and a snapshot of the rules, policies and sources in force are stored against the version.
- Policy evaluation determines what approval that version needs; publishing re-checks everything before writing the sandbox record.

Module	Responsibility
auth.py	Sessions, password hashing, explicit permission matrix, workspace scoping
vision.py	Upload validation, RapidOCR (ONNX), WCAG contrast, CIE Delta-E palette, template-matching logo similarity
evidence.py	Source ingestion (txt/md/pdf), passage splitting, BM25, claim extraction and verdicts
policies.py	Per-version policy evaluation: triggers, required role, distinct approvers, evidence confirmation
intelligence.py	Brand DNA, contradictions, in-memory simulation, campaign consistency, replay diffs
migrations.py	Additive, idempotent column migrations, tested on a copy of the Round 2 database

6 · COMMITMENT ONE

Multimodal brand governance

- **Intake:** PNG/JPEG identified by magic bytes and full decode (never filename/MIME); 4 MB, 64–6000 px, 30 MP limits; corrupt, empty, oversized and renamed files rejected with clear errors; identical re-uploads refused; nothing written to disk.
- **OCR:** RapidOCR runs on the server; each line keeps its box and confidence. Lines under 80% confidence become a finding asking a human to check the transcription.
- **Rules:** the existing rule engine runs on the OCR transcript; matches are mapped back to image regions. Image text cannot be "corrected" in place — the reviewer is told to upload a revision, which becomes a new version.
- **Visual checks:** contrast from a two-colour split inside each text box (WCAG AA 4.5:1 / 3:1), flagged uncertain over varied backgrounds; palette share and CIE76 Delta-E to the brand palette; logo normalised cross-correlation against an admin-uploaded reference, explicitly not proof of authenticity.

Evaluation

Creative	Expected	Found	False pos.	Missed
01-compliant-atlas.png	none	none	none	none
02-violations-guarantee.png	prohibited_term, required_phrase, visual_contrast, visual_logo, visual_palette	prohibited_term, required_phrase, visual_contrast, visual_logo, visual_palette	none	none
03-terminology-uptime.png	preferred_term, required_phrase	preferred_term, required_phrase	none	none
04-low-contrast.png	visual_contrast	visual_contrast	none	none

Four fictional creatives produced by `samples/generate_samples.py`. They were made during development, so the result shows designed behaviour, not generalisation.

7 · COMMITMENT TWO

Evidence-grounded claim verification

- **Sources:** UTF-8 text, Markdown (sections kept) and text-based PDF (page numbers kept). Name, identifier, effective, expiry and review dates and approval status are stored only when supplied. Pending and retired sources are not used.
- **Retrieval:** BM25 over stored passages. Every cited passage is a stored record; its text is copied onto the claim check so history survives source deletion.
- **Verdicts:** *supported* only when most claim terms and every figure (same unit) appear and no absolute wording is unbacked; *contradicted* when a current source gives a different figure/date for the same thing; *stale* when support comes only from an expired or overdue source; *needs review* for partial or negated evidence; *no evidence found* otherwise — explicitly not "false".
- **Governance link:** contradicted and stale claims can trigger approval policies requiring an approver to confirm the evidence was reviewed.

Evaluation

21 claims against 3 sample sources: **19/21** classified as expected; **0** wrongly marked supported; expected document cited for 15/15 claims that need a citation. Both errors were unsupported claims labelled "needs review" — the conservative direction.

Claim	Expected	Actual
Northstar maintains a 99.995% uptime SLA backed by multi-region automated failover.	supported	supported
Northstar Cloud is available in 14 regions.	supported	supported
Northstar accelerates enterprise workload throughput by up to 34% within 90 days.	supported	supported
Atlas Pro costs $49 per member per month.	supported	supported
Atlas Pro launches on November 12, 2026.	supported	supported
Every new Atlas Pro workspace includes a 14-day free trial.	supported	supported
Northstar is SOC 2 Type II certified.	supported	supported
Northstar maintains a 99.9% uptime SLA.	contradicted	contradicted
Northstar Cloud is available in 20 regions.	contradicted	contradicted
Atlas Pro costs $59 per member per month.	contradicted	contradicted
Atlas Pro launches on November 14, 2026.	contradicted	contradicted
Every new Atlas Pro workspace includes a 30-day free trial.	contradicted	contradicted
Northstar accelerates workload throughput by up to 50% within 90 days.	contradicted	contradicted
Northstar is ISO 27001 certified for its managed control plane.	stale	stale
Customer data is encrypted at rest with AES-256.	stale	stale
Northstar is the fastest cloud platform in the world.	unsupported	needs_review

Claim	Expected	Actual
Northstar cuts infrastructure costs by 40% for every customer.	unsupported	unsupported
Northstar is trusted by 10,000 banks worldwide.	unsupported	unsupported
Northstar won the 2026 Cloud Innovation Award.	unsupported	needs_review
Northstar is HIPAA certified for regulated workloads.	needs_review	needs_review
Northstar guarantees 99.995% uptime for every workload.	needs_review	needs_review

8 · COMMITMENT THREE

Enterprise governance and publishing

Control	Implementation
Authentication	PBKDF2-SHA256 (310k iterations, per-user salt); 256-bit session tokens stored as SHA-256; HttpOnly, SameSite=Lax, Secure on HTTPS; 12 h expiry; revoked on logout. No default admin credentials.
Authorisation	Explicit permission matrix (creator / reviewer / admin) checked on every endpoint; non-members get 404; denials inside a workspace are audited.
CSRF / CORS	State-changing calls require a custom header; CORS closed unless configured.
Approval policies	Triggers: open finding >= severity, claim verdict, finding category. Requirements: role, distinct approvers, evidence confirmation. Admin-configurable.
Version binding	Approvals must name the reviewed version; stale versions rejected; edits and revisions reset approval; authors cannot approve their own content; duplicate approvals refused.
Publishing	Sandbox connector: refuses drafts, rejected, unapproved and stale versions; re-checks policies; one record per version (database unique constraint); repeats return the existing record; every attempt audited. Nothing is sent to a third party.
Audit	Logins, logouts, rule/source/policy/member changes, analyses, corrections, decisions, publish attempts and permission denials. An application log in an ordinary table — not tamper-proof.

9–11 · SIGNATURE FEATURES

Brand DNA, consistency graph, decision replay

Brand DNA digital twin

Eight dimensions (tone, terminology, prohibited language, disclosures, claim restrictions, claims & evidence, visual identity, risk & approval) are built only from stored records, each listing the rules or sources behind it and marked configured, thin or missing. No overall score is shown. Contradiction detection separates **definite** conflicts (a required disclosure containing prohibited wording, a replacement that is itself prohibited or discouraged, two replacements for one term) from **possible** ones (same pattern with different outcomes, overlapping patterns with different severities, approved claims with different figures). The simulator applies proposed changes to copies of the rules and reports gained/lost findings, policy impact and new conflicts per item; tests confirm the active data is unchanged.

Cross-channel consistency graph

Campaigns group assets and an optional approved brief. Prices, percentages, quantities and dates are extracted with their sentence; values are only compared when their surrounding wording overlaps, and are labelled confirmed mismatch, uncertain or consistent. Missing required disclosures and high-severity rule conflicts are listed with links to fix each asset. Nothing is rewritten automatically. A test confirms unrelated numbers ("40 engineers" vs "50 GB") are not reported as contradictions.

Decision replay

Compares any two versions: word-level diff; findings resolved, new, persisted or changed; the rulebook snapshot stored with each analysis (recorded from Round 3 onward — older runs are reported as having no snapshot rather than reconstructed); decisions; publications; and the audit timeline. Reviewers can run a counterfactual (disable a rule) on a historical version without changing anything.

10 · TESTING

Methodology and results

63 passed, 0 failed (pytest, 29 Oct 2026). Frontend: `tsc -b && vite build` succeeds. Tests use an isolated temporary SQLite database and never touch demo or production data.

- Security: anonymous access, CSRF header, password hashing, session revocation after logout, creator->admin actions, reviewer edits, cross-workspace reads and writes, audited denials, last-admin protection.
- Workflow: unanalysed and stale-version approvals, missing version, notes required, self-approval, duplicate approval, two-approver policy, evidence-confirmation policy, approval reset on edit, invalid transitions.
- Publishing: drafts, creators, unknown channel, stale version, rejected content, duplicate publish, export download, refusal after edit.
- Inputs: malformed JSON, missing fields, whitespace-only and oversized text, invalid IDs, empty/corrupt/wrong-type/tiny/oversized/renamed images, bad source types and dates, PDF ingestion.
- Features: OCR->rule->region mapping, contrast maths, Delta-E, logo match, eight claim-verdict cases, Brand DNA provenance, contradictions, simulation immutability, campaign mismatches with passages, replay diff and counterfactual, empty workspaces.
- Migration: Round 2 database copy upgraded in place; existing rows kept; demo personas and Round 3 data added; seeded approved item publishable.
- Browser: sign-in, creative analysis, claims, campaign graph, Brand DNA and approval panel checked in Chrome at 1440 px. Phone-width layout of the new pages was **not** verified in this round.

12–15 · LIMITS AND ROADMAP

What is not done, honestly

Known limitations

- BM25 misses paraphrases with no shared words; contradictory wording without differing figures is routed to review, not labelled contradicted.
- OCR can misread stylised text; contrast estimates weaken over gradients and photos; logo similarity is not authenticity or placement.
- Evaluation sets are small, fictional and team-authored; no independent labelling or user research.
- Publishing is a sandbox; no SSO; login throttling is per serverless instance; the demo workspace is shared by all visitors.
- Deployment of the Round 3 build depends on the OCR runtime loading on the host's Linux image; if it cannot, creative upload returns a clear error and text features continue to work.

Changes since Round 2

- Persona switcher replaced with real authentication and server-side authorisation; CORS wildcard removed.
- New: creatives, evidence library, claim checks, policies, publishing, Brand DNA, campaigns, replay, governance page.
- Additive migrations; Round 2 demo data upgraded in place. Test suite grew from 11 to 63.

Roadmap

- OIDC/SAML SSO; real CMS and social connectors behind the same publish guard.
- Hybrid lexical + embedding retrieval with the same conservative verdict layer; negation-aware contradiction detection.
- Layout checks (logo placement, safe zones), video frames, and an independently labelled evaluation set.

16 · Links

Source repository: https://github.com/RonitM2k06/Auditra
Live application: the Round 3 build has not been deployed yet; no Round 3 URL is claimed here.